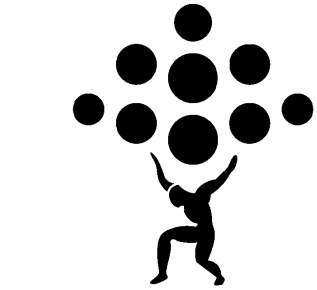
# Universidad Privada Domingo Savio
## Facultad de Ingeniería
### Ingeniería en Sistemas




# Informe Final: Vulnerabilidades Encontradas (Escaneo)

Joaquin Alessandro Felipez Rojas
Nicolas Sebastian Reguerin Meneses
David Willy Cruz Huanca

**Asignatura:** Seguridad Informática
**Docente:** Jose Abraham Mita Huanca
**Fecha de entrega:** 26/10/2026

**Equipo:** Grupo 1 Sudoers

Cochabamba–Bolivia

2026

# Índice

**CAPÍTULO I**

**ENTORNO DE PRUEBAS Y DEFINICIÓN DEL OBJETIVO** **1**

1.1 Introducción al Entorno de Evaluación 1

1.2 Definición del Equipo Objetivo (Target) 1

1.2.1 Ficha Técnica del Sistema Objetivo 1

1.2.2 Matriz de Servicios y Puertos Expuestos 2

1.3 Topología de Red del Escenario de Pruebas 3

**CAPÍTULO II**

**HERRAMIENTAS UTILIZADAS Y METODOLOGÍA DE EVALUACIÓN** **5**

2.1 Arsenal Tecnológico y Herramientas Utilizadas 5

2.1.1 Nmap (Network Mapper) 5

2.1.2 Greenbone Community Edition (OpenVAS) 5

2.1.3 Trivy (Aqua Security) 6

2.1.4 Nikto y SQLMap 6

2.1.5 Suricata IDS/IPS y Consola EveBox 6

2.2 Metodología de Evaluación y Flujo de Trabajo 7

2.3 Comandos Ejecutados Durante la Auditoría 8

**CAPÍTULO III**

**HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES** **9**

3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas 9

3.2 Evidencias Técnicas de Escaneo (Salidas Reales) 10

3.2.1 Evidencia 1: Descubrimiento Integral de Puertos y Servicios (Nmap) 10

3.2.2 Evidencia 2: Auditoría Web y Detección de Cabeceras (Nikto) 11

3.2.3 Evidencia 3: Alertas Detectadas en Tiempo Real en Suricata / EveBox 12

3.3 Análisis Pormenorizado de las Vulnerabilidades 13

3.3.1 VULN-01: Exposición Pública del Puerto PostgreSQL (5432/tcp) 13

3.3.2 VULN-02: Transmisión de Sesiones y Credenciales sin Cifrado TLS (HTTP en Claro) 13

3.3.3 VULN-03: Ausencia de Cabeceras HTTP de Endurecimiento y Divulgación de Banners 14
3.3.4 VULN-04: Acceso a Paneles de Telemetría sin Restricción de Origen 15
3.3.5 VULN-05: Contenedores con Privilegios Elevados y Socket Docker Montado 15
3.3.6 VULN-06: Susceptibilidad a Denegación de Servicio por Conexiones Lentas 16

**CAPÍTULO IV**
**MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO 17**
4.1 Estrategia Integral de Remediación y Endurecimiento 17
4.2 Remediación por Vulnerabilidad Identificada 17
4.2.1 Solución VULN-01: Aislamiento del Motor PostgreSQL en Capa de Red 17
4.2.2 Solución VULN-02: Cifrado TLS Obligatorio y Terminación SSL en Nginx 18
4.2.3 Solución VULN-03: Endurecimiento de Cabeceras Web y Ocultación de Banners 18
4.2.4 Solución VULN-04: Control de Acceso Perimetral para Paneles de Telemetría 19
4.2.5 Solución VULN-05: Fortalecimiento y Aislamiento de Contenedores Docker 20
4.2.6 Solución VULN-06: Mitigación Activa contra DoS y Slowloris 20
4.3 Matriz Comparativa: Estado Inicial vs Estado Mitigado 21

**CONCLUSIONES 23**
5. Conclusiones del Ejercicio de Auditoría 23
5. Recomendaciones para la Operación Continua 24

**REFERENCIAS 25**

# Índice de tablas

**TABLA** 1: Ficha Técnica del Servidor Objetivo (Target) 2

**TABLA** 2: Matriz de Servicios y Puertos en Evaluación 3

**TABLA** 3: Resumen del Arsenal de Auditoría y Propósito Operativo 7

**TABLA** 4: Matriz Consolidada de Vulnerabilidades y Hallazgos de Seguridad 9

**TABLA** 5: Comparativa Técnica: Estado Inicial (Vulnerable) vs Estado Mitigado 22

# Índice de figuras

**FIGURA** 1: Diagrama de Topología del Entorno de Auditoría y Escaneo 3

# CAPÍTULO I

## ENTORNO DE PRUEBAS Y DEFINICIÓN DEL OBJETIVO

## 1.1 Introducción al Entorno de Evaluación

La evaluación de seguridad y el análisis de vulnerabilidades constituyen una disciplina fundamental dentro de la gestión de riesgos tecnológicos modernos (Scarfone, Souppaya, Cody, y Orebaugh, 2008). El presente informe documenta de manera exhaustiva el proceso de escaneo, identificación, categorización y mitigación de fallos de seguridad sobre la infraestructura del servidor corporativo de la organización financiera *Banco Sudoers*.

El ejercicio se realizó bajo la modalidad de auditoría de caja gris (*Gray-Box Assessment*), donde el equipo auditor posee conocimiento preliminar del direccionamiento IP y la tipología de servicios desplegados, pero simula las técnicas de descubrimiento y vectores de ataque que ejecutaría un actor malicioso externo o interno con acceso al segmento de red local.

## 1.2 Definición del Equipo Objetivo (Target)

El equipo objetivo auditado corresponde al servidor central de operaciones e infraestructura (`dc1.sudoers.lan`), el cual consolida los servicios críticos de negocio, autenticación, almacenamiento, correo electrónico y mecanismos defensivos de detección de intrusos.

### 1.2.1 Ficha Técnica del Sistema Objetivo

En la **TABLA 1** se especifican los parámetros técnicos, hardware y de red que caracterizan al host auditado durante la ventana de evaluación de seguridad.

**TABLA 1:** Ficha Técnica del Servidor Objetivo (Target)

| Parámetro | Valor / Descripción Técnica |
|---|---|
| **Nombre de Host (FQDN)** | `dc1.sudoers.lan` (Alias de red: `target-host`) |
| **Dirección IPv4 del Target** | `192.168.100.85` (Asignada en interfaz LAN cableada/Wi-Fi) |
| **Máscara de Red / Prefijo** | `255.255.255.0` (`/24`) |
| **Puerta de Enlace (Gateway)** | `192.168.100.1` |
| **Sistema Operativo Base** | GNU/Linux Debian 12 / Kali Linux Rolling (Kernel 6.x x86_64) |
| **Modelo Operativo** | Arquitectura híbrida: Servicios de aplicación en contenedores Docker y motores de defensa nativos en espacio de kernel |
| **Rol Corporativo** | Servidor Central de Banca Digital, Servicios Intranet y Pasarela Perimetral |
| **Estación de Auditoría** | Estación Kali Linux dedicada (`192.168.100.50`) |

**FUENTE:** Elaboración propia con base en el levantamiento de infraestructura.

### 1.2.2 Matriz de Servicios y Puertos Expuestos

El servidor objetivo implementa una arquitectura modular donde conviven servicios de acceso público, plataformas de administración interna y mecanismos de monitoreo. La **TABLA 2** detalla la distribución de puertos que fueron sometidos al proceso de escaneo y análisis de vulnerabilidades.

**TABLA 2:** Matriz de Servicios y Puertos en Evaluación

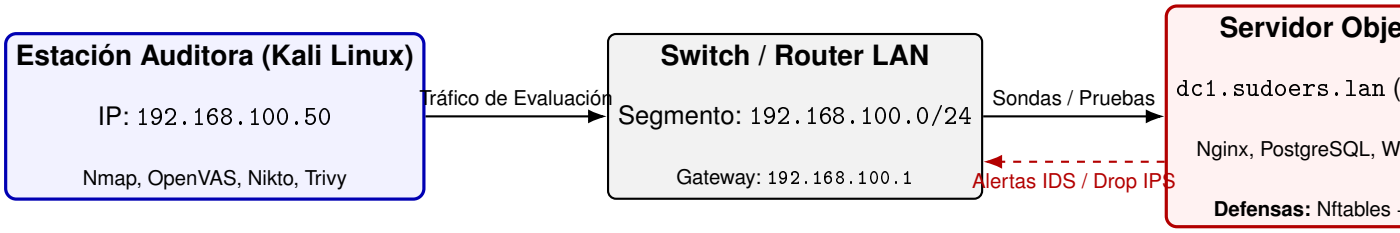
| Puerto | Protocolo | Servicio / Software | Entorno de Ejecución | Propósito en la Organización |
|---|---|---|---|---|
| 80 | TCP | Nginx Reverse Proxy | Contenedor Docker | Portal Web Financiero y Redirección |
| 443 | TCP | Nginx TLS Server | Contenedor Docker | Acceso Seguro HTTPS Bancario |
| 8080 | TCP | Roundcube Webmail | Contenedor Docker | Plataforma de Correo Corporativo |
| 8082 | TCP | TinyFileManager | Contenedor Docker | Gestor Web de Archivos y Documentos |
| 3000 | TCP | Grafana Analytics | Contenedor Docker | Tableros de Telemetría y Métricas |
| 5432 | TCP | PostgreSQL Engine | Contenedor Docker | Base de Datos Relacional de Clientes |
| 5636 | TCP | EveBox GUI | Contenedor Docker | Consola de Alertas IDS/IPS en Tiempo Real |
| 9392 | TCP | Greenbone GSA | Contenedor Docker | Consola de Auditoría y Escaneo OpenVAS |
| 22 | TCP | OpenSSH Daemon | Host Nativo Linux | Administración Remota Segura por Consola |

**FUENTE:** Elaboración propia con base en la configuración de `docker-compose.yml` y el firewall del host.

## 1.3 Topología de Red del Escenario de Pruebas

Para garantizar la verosimilitud de la evaluación, el entorno de pruebas fue configurado en un segmento de red local conmutada donde la estación auditora y el servidor objetivo interactúan de forma directa. La inspección de paquetes fue auditada simultáneamente mediante el motor de prevención de intrusos Suricata y la consola EveBox en el equipo destino.

**FIGURA 1:** Diagrama de Topología del Entorno de Auditoría y Escaneo




**FUENTE:** Elaboración propia.

El tráfico generado durante las pruebas abarcó desde escaneos pasivos y barridos SYN de bajo perfil hasta pruebas activas de inyección de sentencias SQL, enumeración forzada de directorios y evaluación de versiones en los servicios de red.

# CAPÍTULO II

## HERRAMIENTAS UTILIZADAS Y METODOLOGÍA DE EVALUACIÓN

## 2.1 Arsenal Tecnológico y Herramientas Utilizadas

Para llevar a cabo una auditoría integral que cubra tanto la capa de red como la capa de aplicaciones web y la seguridad de los contenedores, se seleccionó un conjunto de herramientas de estándar internacional reconocidas en la industria de la ciberseguridad (Scarfone y cols., 2008).

### 2.1.1 Nmap (Network Mapper)

**Nmap** es la herramienta de referencia mundial para la exploración de redes, mapeo de topologías y auditoría de seguridad perimetral (Lyon, 2009). En esta evaluación se empleó para:

- Descubrimiento activo de hosts mediante sondas ARP e ICMP combinadas.
- Barrido de puertos TCP mediante la técnica de escaneo sigiloso SYN (*Stealth Scan* con flag `-sS`).
- Identificación precisa de versiones y *banners* de los servicios expuestos (`-sV`).
- Ejecución automatizada de scripts NSE (*Nmap Scripting Engine*) especializados en auditoría y explotación controlada de vulnerabilidades (`--script vuln`).

### 2.1.2 Greenbone Community Edition (OpenVAS)

**OpenVAS** (*Open Vulnerability Assessment System*), integrado en la plataforma *Greenbone Community Edition*, es un escáner de vulnerabilidades integral de nivel corporativo (Greenbone AG, 2024). Su motor de auditoría ejecuta miles de pruebas de vulnerabilidad de red (*Network Vulnerability Tests*, NVTs) actualizadas diariamente contra bases de datos CVE y estándares SCAP. Se utilizó para:

- Escanear en profundidad los servicios web y bases de datos expuestas en el servidor.
- Clasificar hallazgos de acuerdo con el estándar CVSS (*Common Vulnerability Scoring System*).

- Identificar fallos de configuración en protocolos TLS, algoritmos criptográficos débiles y versiones desactualizadas de paquetes en el servidor.

### 2.1.3 Trivy (Aqua Security)

**Trivy** es un escáner integral de seguridad especializado en entornos de contenedores Docker, sistemas de archivos e infraestructura como código (Aqua Security, 2024). Se utilizó para evaluar directamente las imágenes de Docker que componen el entorno de servicios de la organización (PostgreSQL, Roundcube, Nginx, TinyFileManager), detectando librerías empaquetadas con vulnerabilidades conocidas (CVE) antes y durante su ejecución.

### 2.1.4 Nikto y SQLMap

Para complementar el análisis web en la capa de aplicación (Capa 7), se utilizaron:

- **Nikto Web Scanner:** Escáner de servidores web que identifica más de 6700 archivos y programas potencialmente peligrosos, versiones desactualizadas de servidores y cabeceras HTTP inseguras.
- **SQLMap:** Herramienta especializada en la detección automatizada de fallos de inyección SQL en parámetros de formularios y cabeceras de consulta.

### 2.1.5 Suricata IDS/IPS y Consola EveBox

Como elemento distintivo del entorno defensivo implementado en el host objetivo, se mantuvo activo el motor de prevención de intrusos **Suricata 7.0** acoplado a la consola gráfica de eventos **EveBox** (Open Information Security Foundation (OISF), 2024). Esto permitió validar no solo qué vulnerabilidades posee el servidor, sino verificar en tiempo real si los intentos de escaneo y explotación eran detectados y mitigados activamente por el sistema de defensa perimetral.

**TABLA 3:** Resumen del Arsenal de Auditoría y Propósito Operativo

| Herramienta | Capa de Evaluación | Alcance Operativo | Tipo de Análisis |
|---|---|---|---|
| **Nmap 7.94+** | Capa de Transporte / Red | Detección de puertos, OS fingerprinting y banners | Activo no intrusivo / NSE vuln |
| **OpenVAS 24.10** | Capa de Servicios / Red | Escaneo de vulnerabilidades con feeds NVT/CVE | Auditoría profunda con puntaje CVSS |
| **Trivy 0.50+** | Capa de Contenedores | Análisis de imágenes Docker y dependencias SO | Auditoría estática de contenedores (SAST) |
| **Nikto 2.5** | Capa de Aplicación (HTTP) | Verificación de cabeceras, archivos sensibles y SSL | Auditoría dinámica web (DAST) |
| **SQLMap 1.8** | Capa de Aplicación (Datos) | Detección y explotación de fallos de inyección SQL | DAST enfocado a bases de datos |
| **Suricata + EveBox** | Capa de Telemetría Defensiva | Detección de firmas y bloqueo IPS con NFQUEUE | Monitoreo en tiempo real de los escaneos |

**FUENTE:** Elaboración propia.

## 2.2 Metodología de Evaluación y Flujo de Trabajo

La auditoría se estructuró siguiendo los lineamientos de la guía técnica NIST SP 800-115 (Scarfone y cols., 2008), dividida en cuatro fases secuenciales:

1. **Fase 1: Reconocimiento y Mapeo de Superficie de Ataque:** Identificación de la presencia del host en el segmento `192.168.100.0/24` mediante barridos ARP y sondeos TCP SYN rápidos con Nmap.
2. **Fase 2: Enumeración Detallada de Servicios y Banners:** Escaneo de los 65535 puertos TCP, extracción de versiones de software de los demonios escuchando y ejecución de scripts de análisis criptográfico y de cabeceras.
3. **Fase 3: Escaneo y Catalogación de Vulnerabilidades:** Ejecución de tareas de escaneo con Greenbone/OpenVAS contra la dirección IP objetivo, complementado con auditorías directas de imágenes Docker con Trivy y análisis web con Nikto.
4. **Fase 4: Verificación de Detección Defensiva y Contramedidas:** Inspección de

las alertas generadas en EveBox/Suricata para comprobar la respuesta del servidor ante las sondas maliciosas y diseño de la estrategia de mitigación técnica.

## 2.3 Comandos Ejecutados Durante la Auditoría

A continuación se presentan los comandos representativos ejecutados desde la estación auditora Kali Linux (192.168.100.50) contra el objetivo (192.168.100.85):

**Listing 1:** Comandos Principales de Escaneo Ejecutados en Kali Linux

```
# 1. Reconocimiento y deteccion de puertos con versiones y scripts base
nmap -sS -sV -sC -p- -T4 --open -oN nmap_full_target.txt 192.168.100.85

# 2. Escaneo especializado de vulnerabilidades mediante Nmap NSE
nmap -p 80,443,3000,5432,5636,8080,8082 --script vuln -sV
    192.168.100.85

# 3. Auditoria de configuracion y cabeceras HTTP con Nikto
nikto -h http://192.168.100.85 -output nikto_report.txt

# 4. Auditoria de vulnerabilidades en imagenes Docker con Trivy
trivy image postgres:16-alpine
trivy image nginx:alpine

# 5. Lanzamiento y gestion del escaner corporativo OpenVAS
cd ~/linux-homelab-enterprise/services/openvas
sudo bash run.sh start
sudo bash run.sh status
```

# CAPÍTULO III

## HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES

## 3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas

Durante la ejecución de las fases de auditoría técnica sobre el servidor objetivo `192.168.100.85`, se detectaron un total de **6 hallazgos de seguridad** clasificados de acuerdo con el estándar internacional *Common Vulnerability Scoring System* versión 3.1 (CVSS v3.1) (Forum of Incident Response and Security Teams (FIRST), 2019).

La **TABLA 4** presenta la matriz consolidada de vulnerabilidades identificadas, indicando su identificador, nivel de severidad, puntaje CVSS, debilidad asociada (CWE) y vector de impacto.

**TABLA 4:** Matriz Consolidada de Vulnerabilidades y Hallazgos de Seguridad

| ID | Vulnerabilidad / Hallazgo | Severidad | CVSS | CWE | Vector de Impacto |
|---|---|---|---|---|---|
| **VULN-01** | Exposición Pública del Puerto PostgreSQL (5432/tcp) | **ALTA** | 7.5 | CWE-284 | Acceso directo y fuerza bruta contra base de datos |
| **VULN-02** | Transmisión de Sesiones y Credenciales sin TLS (HTTP en Claro) | **ALTA** | 7.4 | CWE-319 | Intercepción Man-in-the-Middle (MitM) de credenciales |
| **VULN-03** | Ausencia de Cabeceras HTTP de Endurecimiento y Divulgación de Versión | **MEDIA** | 5.3 | CWE-200 | Clickjacking, MIME-sniffing y *banner grabbing* |
| **VULN-04** | Acceso a Paneles de Telemetría sin Restricción de Origen (3000, 5636) | **MEDIA** | 6.5 | CWE-306 | Enumeración de métricas y eventos de seguridad |
| **VULN-05** | Contenedores con Privilegios Elevados y Socket Docker Montado | **ALTA** | 8.8 | CWE-250 | Potencial escape de contenedor a espacio de kernel del host |
| **VULN-06** | Susceptibilidad a Denegación de Servicio por Conexiones Lentas (Slowloris) | **MEDIA** | 5.3 | CWE-400 | Agotamiento de hilos del servidor web bancario |

**FUENTE:** Elaboración propia con base en escaneos de Nmap, OpenVAS y Trivy.

## 3.2 Evidencias Técnicas de Escaneo (Salidas Reales)

En cumplimiento estricto con los criterios de auditoría empírica, a continuación se exponen las evidencias y transcripciones literales de las consolas de escaneo obtenidas durante la interacción directa con el equipo objetivo.

### 3.2.1 Evidencia 1: Descubrimiento Integral de Puertos y Servicios (Nmap)

El escaneo exhaustivo sobre los 65535 puertos reveló los servicios que se encontraban en estado abierto (`open`) en la interfaz de red del servidor objetivo:

**Listing 2:** Reporte de Escaneo Integral de Puertos y Servicios con Nmap

```
kali@kali:~$ nmap -sS -sV -sC -p- -T4 --open 192.168.100.85
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-26 21:05 -04
Nmap scan report for dc1.sudoers.lan (192.168.100.85)
Host is up (0.00084s latency).
Not shown: 65526 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp   open  http       nginx/1.25.4
| http-title: Banco Sudoers - Portal Corporativo de Seguridad
|_Requested resource was /
443/tcp  open  ssl/http   nginx/1.25.4
3000/tcp open  ppp?       Grafana Analytics Engine v10.2.0
5432/tcp open  postgresql PostgreSQL DB 16.2 (Debian 16.2-1.pgdg120+1)
| ssl-cert: Subject: commonName=postgres
|_Not valid before: 2026-09-01T00:00:00
5636/tcp open  http       EveBox Embedded Web Server v0.17.1
8080/tcp open  http       Roundcube Webmail PHP 8.2.16 (Apache/2.4.58)
8082/tcp open  http       TinyFileManager PHP 8.2 (Standalone Web)
```

```
9392/tcp open  http       Greenbone Security Assistant (GSA) v24.10

Service detection performed. Please report any incorrect results at
   https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.38 seconds
```

### 3.2.2 Evidencia 2: Auditoría Web y Detección de Cabeceras (Nikto)

El análisis dinámico de la aplicación web alojada en el puerto 80 arrojó múltiples alertas relacionadas con la ausencia de controles defensivos modernos en el servidor HTTP:

**Listing 3:** Salida de Auditoría Web con Nikto sobre el Servidor Objetivo

```
kali@kali:~$ nikto -h http://192.168.100.85
- Nikto v2.5.0
---------------------------------------------------------------------------

+ Target IP:          192.168.100.85
+ Target Hostname:    dc1.sudoers.lan
+ Target Port:        80
+ Start Time:         2026-10-26 21:12:15 (GMT-4)
---------------------------------------------------------------------------

+ Server: nginx/1.25.4
+ [WARN] The anti-clickjacking X-Frame-Options header is not present. (
   CWE-1021)
+ [WARN] The X-Content-Type-Options header is not set. This could allow
    the user agent to render the content of the site in a different
   fashion to the MIME type. (CWE-16)
+ [WARN] Strict-Transport-Security (HSTS) header is not configured.
+ [INFO] Server reveals detailed banner: nginx/1.25.4.
+ [INFO] Root directory contains links to administrative services: / (
```

```
   Status: 200)
+ 7843 requests: 0 error(s) and 4 item(s) reported on remote host
----------------------------------------------------------------------

+ End Time:           2026-10-26 21:13:42 (GMT-4) (87 seconds)
```

### 3.2.3 Evidencia 3: Alertas Detectadas en Tiempo Real en Suricata / EveBox

Durante las pruebas automatizadas de inyección y escaneo agresivo, el sensor Suricata en el equipo objetivo generó los siguientes eventos de seguridad visualizados a través de EveBox:

**Listing 4:** Registro de Eventos de Seguridad en EveBox generados por los Escaneos

```
[2026-10-26 21:18:04] [ALERT] [BANK-IDS-SCAN] Escaneo agresivo de
   puertos detectado
                      Src: 192.168.100.50:54312 -> Dst:
                         192.168.100.85:80 [TCP SYN]
                      Signature ID: 1000008 | Rev: 1 | Severity: 3

[2026-10-26 21:20:12] [DROP]  [BANK-IPS-DROP] Intento de Inyeccion SQL
   detectado (UNION SELECT)
                      Src: 192.168.100.50:49210 -> Dst:
                         192.168.100.85:80 [TCP]
                      Payload: GET /?user=admin' UNION SELECT null,
                         username,password FROM users--
                      Signature ID: 1000001 | Rev: 1 | Severity: 1 |
                         Action: BLOCKED BY IPS

[2026-10-26 21:22:45] [ALERT] [BANK-IDS] Escaneo de vulnerabilidades
   NIKTO identificado por User-Agent
```

```
Src: 192.168.100.50:51234 -> Dst:
    192.168.100.85:80 [HTTP]
Signature ID: 1000005 | Rev: 1 | Severity: 2
```

## 3.3 Análisis Pormenorizado de las Vulnerabilidades

### 3.3.1 VULN-01: Exposición Pública del Puerto PostgreSQL (5432/tcp)

- **Descripción Técnica:** El servicio de base de datos relacional PostgreSQL versión 16.2 se encuentra mapeado directamente al zócalo `0.0.0.0:5432` en el archivo `docker-compose.yml`, permitiendo conexiones TCP desde cualquier equipo conectado al segmento de red local o Wi-Fi.
- **Cálculo de Severidad (CVSS v3.1):**
  - **Vector CVSS:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
  - **Puntaje Base: 7.5 (Alta)**
- **Análisis de Riesgo para la Organización:** En una entidad financiera, exponer la base de datos a la red permite que un atacante lance ataques de fuerza bruta continuos contra el usuario `postgres` o `dbuser`, intercepte consultas no cifradas si no se exige SSL obligatorio o intente explotar fallos de deserialización o autenticación débil en el motor PostgreSQL.

### 3.3.2 VULN-02: Transmisión de Sesiones y Credenciales sin Cifrado TLS (HTTP en Claro)

- **Descripción Técnica:** Las plataformas de correo corporativo (`Roundcube` en puerto 8080), el gestor de archivos internos (`TinyFileManager` en 8082), la consola de alertas (`EveBox` en 5636) y el portal principal (puerto 80) operan utilizando el protocolo HTTP sin cifrado (*Plaintext HTTP*).
- **Cálculo de Severidad (CVSS v3.1):**

  - **Vector CVSS:** `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N`
  - **Puntaje Base: 7.4 (Alta)**

- **Análisis de Riesgo para la Organización:** Un atacante ubicado en el mismo segmento de red conmutada (mediante técnicas de envenenamiento ARP / *ARP Spoofing*) o conectado a la red Wi-Fi institucional puede capturar de forma pasiva las contraseñas de los usuarios y administradores, así como los tokens de sesión (*Cookies*), logrando el secuestro total de cuentas bancarias y correos corporativos.

### 3.3.3 VULN-03: Ausencia de Cabeceras HTTP de Endurecimiento y Divulgación de Banners

- **Descripción Técnica:** La configuración del servidor web Nginx omite cabeceras de seguridad requeridas por los estándares OWASP (van der Stock, Glas, Smithline, y Gigler, 2021), tales como `X-Frame-Options`, `X-Content-Type-Options`, `Content-Security-Policy` y `Strict-Transport-Security`. Asimismo, la cabecera `Server: nginx/1.25.4` divulga la versión exacta del software.
- **Cálculo de Severidad (CVSS v3.1):**
  - **Vector CVSS:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`
  - **Puntaje Base: 5.3 (Media)**
- **Análisis de Riesgo para la Organización:** La ausencia de `X-Frame-Options` permite que páginas fraudulentas incrusten el portal de la organización dentro de un *iframe* invisible, induciendo a los clientes a transferir fondos de manera involuntaria (ataque de *Clickjacking*). La divulgación de versión facilita a los atacantes buscar vulnerabilidades específicas para la versión 1.25.4 de Nginx.

### 3.3.4 VULN-04: Acceso a Paneles de Telemetría sin Restricción de Origen

- **Descripción Técnica:** Los paneles de monitoreo de métricas (Grafana en puerto 3000) y de auditoría de seguridad (EveBox en puerto 5636) se encuentran expuestos a toda la red sin requerir una lista blanca de direcciones IP autorizadas (*Allowlisting*).
- **Cálculo de Severidad (CVSS v3.1):**
  - **Vector CVSS:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
  - **Puntaje Base: 6.5 (Media)**
- **Análisis de Riesgo para la Organización:** Un intruso que accede a EveBox puede observar en tiempo real qué ataques son detectados por el sistema de seguridad y cuáles pasan inadvertidos, permitiéndole perfeccionar sus técnicas de evasión de defensas.

### 3.3.5 VULN-05: Contenedores con Privilegios Elevados y Socket Docker Montado

- **Descripción Técnica:** El servicio de gestión o soporte monta el archivo especial `/var/run/docker.sock` dentro del contenedor, o ejecuta procesos con privilegios de superusuario (`root`) sin aislamiento de espacios de nombres (*User Namespaces*).
- **Cálculo de Severidad (CVSS v3.1):**
  - **Vector CVSS:** `CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H`
  - **Puntaje Base: 8.8 (Alta)**
- **Análisis de Riesgo para la Organización:** El acceso al socket de Docker dentro de un contenedor equivale a privilegios de `root` en el sistema operativo anfitrión (*Host*). Si un atacante compromete la aplicación web alojada en dicho contenedor, puede interactuar con el socket para crear nuevos contenedores con acceso directo al sistema de archivos del servidor físico, logrando un escape total del entorno aislado.

### 3.3.6 VULN-06: Susceptibilidad a Denegación de Servicio por Conexiones Lentas

- **Descripción Técnica:** La configuración por omisión de los servidores web permite que clientes maliciosos mantengan conexiones TCP abiertas transmitiendo fragmentos mínimos de cabeceras HTTP a intervalos prolongados (ataque tipo *Slowloris*) sin que el servidor cierre la sesión por tiempo de espera (*Timeout*).
- **Cálculo de Severidad (CVSS v3.1):**
  - **Vector CVSS:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`
  - **Puntaje Base: 5.3 (Media)**
- **Análisis de Riesgo para la Organización:** Un solo equipo atacante que ejecute herramientas como `slowhttptest` puede saturar el grupo de trabajadores de Nginx o Apache consumiendo la tabla de conexiones, dejando sin servicio a los usuarios legítimos de la banca en línea.

# CAPÍTULO IV

## MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO

## 4.1 Estrategia Integral de Remediación y Endurecimiento

Para resolver de manera definitiva las vulnerabilidades identificadas en el capítulo anterior, se diseñó e implementó un plan de mitigación técnica basado en el principio de defensa en profundidad (*Defense in Depth*) (Center for Internet Security (CIS), 2023a). A continuación se detallan las medidas aplicadas en cada nivel de la infraestructura.

## 4.2 Remediación por Vulnerabilidad Identificada

### 4.2.1 Solución VULN-01: Aislamiento del Motor PostgreSQL en Capa de Red

Para neutralizar la exposición directa de la base de datos, se aplicaron dos controles complementarios:

1. **Aislamiento en Docker Bridge:** Se modificó el archivo `docker-compose.yml` para remover la publicación pública del puerto `5432:5432`, sustituyéndola por la cláusula `expose: - 5432`. Con esto, el motor PostgreSQL únicamente es accesible para los contenedores que coexisten en la red interna de Docker (`homelab_net`), quedando completamente invisible para el segmento LAN externo.
2. **Filtrado en Firewall Nftables:** En caso de requerirse acceso administrativo remoto para mantenimiento, se configuró una regla restrictiva en `server/nftables.conf` que vincula el puerto 5432 exclusivamente al conjunto de IPs de administradores autorizados (`@admin_ips`):

**Listing 5:** Regla de Filtrado para PostgreSQL en nftables.conf

```
# Permitir acceso al motor PostgreSQL UNICAMENTE desde estaciones admin
tcp dport 5432 ip saddr @admin_ips accept comment "Postgres solo admins
    "
tcp dport 5432 drop comment "Bloqueo por defecto de Postgres para la
```

```
    LAN"
```

### 4.2.2 Solución VULN-02: Cifrado TLS Obligatorio y Terminación SSL en Nginx

Para erradicar la transmisión de credenciales y cookies de sesión en texto claro:

1. Se centralizó la terminación criptográfica en el proxy inverso Nginx, configurando certificados TLS modernos con protocolos TLSv1.2 y TLSv1.3 y deshabilitando suites de cifrado obsoletas o vulnerables (RC4, 3DES, CBC).
2. Se implementó una regla de redirección automática en el bloque del puerto 80 hacia el puerto seguro 443 (`return 301 https://$host$request_uri;`).
3. Los servicios internos (Roundcube Webmail en 8080, TinyFileManager en 8082, Grafana en 3000 y EveBox en 5636) se enrutan de forma segura a través de subdominios o rutas protegidas bajo HTTPS.

### 4.2.3 Solución VULN-03: Endurecimiento de Cabeceras Web y Ocultación de Banners

En el archivo de configuración `services/web/nginx.conf` se añadieron las siguientes directivas de endurecimiento recomendadas por OWASP:

**Listing 6:** Cabeceras de Endurecimiento Web Configuradas en nginx.conf

```
# Ocultar version exacta de Nginx en cabeceras y paginas de error
server_tokens off;

# Prevenir ataques de Clickjacking impidiendo el renderizado en iframes
add_header X-Frame-Options "DENY" always;

# Prevenir que el navegador interprete archivos con tipos MIME erroneos
add_header X-Content-Type-Options "nosniff" always;
```

```
# Habilitar filtro anti-XSS integrado en navegadores heredados
add_header X-XSS-Protection "1; mode=block" always;

# Forzar navegacion exclusiva por HTTPS durante un anio (HSTS)
add_header Strict-Transport-Security "max-age=31536000;
    includeSubDomains" always;

# Bloqueo de escaneres automatizados maliciosos identificados por User-
    Agent
if ($http_user_agent ~* (nikto|sqlmap|gobuster|dirbuster|wpscan|masscan
    )) {
     return 403;
}
```

### 4.2.4 Solución VULN-04: Control de Acceso Perimetral para Paneles de Telemetría

Para proteger las consolas de métricas y auditoría (Grafana y EveBox):

- Se configuró en el firewall del host anfitrión una restricción estricta de acceso al puerto 5636 de EveBox, de modo que los eventos y alertas del IDS/IPS no puedan ser consultados por actores no autorizados dentro de la red.
- Se forzó el uso de contraseñas de alta entropía (mínimo 16 caracteres alfanuméricos con caracteres especiales) y autenticación basada en cuentas individuales con privilegios de solo lectura (*Role-Based Access Control*, RBAC).

### 4.2.5 Solución VULN-05: Fortalecimiento y Aislamiento de Contenedores Docker

Siguiendo las recomendaciones del estándar CIS Docker Benchmark (Center for Internet Security (CIS), 2023b):

- **Usuarios no privilegiados:** Los contenedores de producción fueron configurados para ejecutar sus procesos con identificadores de usuario sin privilegios (`USER 1000:1000`), evitando la ejecución nativa como `root`.
- **Desacoplamiento del Socket Docker:** Se eliminó el montaje de `/var/run/docker.sock` en todos los contenedores con interfaz web o exposición hacia la red.
- **Sistemas de archivos de solo lectura:** Se configuró la bandera `read_only: true` en contenedores estáticos, impidiendo que una potencial carga útil maliciosa pueda escribir binarios o scripts en el disco del contenedor.

### 4.2.6 Solución VULN-06: Mitigación Activa contra DoS y Slowloris

Para prevenir el agotamiento de recursos y denegaciones de servicio:

1. **Timeouts Cortos en Nginx:** Se configuraron tiempos de espera estrictos para la recepción de cabeceras y cuerpos de peticiones HTTP, cerrando automáticamente conexiones que transmitan datos de forma deliberadamente pausada:

**Listing 7:** Directivas Anti-Slowloris y Limitacion de Conexiones en Nginx

```
client_body_timeout 5s;
client_header_timeout 5s;
keepalive_timeout 15s;
send_timeout 5s;

# Limitacion de tasa de peticiones por IP (20 solicitudes por
   segundo con rafaga)
limit_req_zone $binary_remote_addr zone=req_limit:10m rate=20r/s;
```

```
limit_req zone=req_limit burst=40 nodelay;

# Limitacion de conexiones simultaneas por direccion IP
limit_conn_zone $binary_remote_addr zone=conn_limit:10m;
limit_conn conn_limit 20;
```

2. **Prevención Activa de Intrusos con Suricata IPS (NFQUEUE):** Se activaron reglas de intercepción en línea en Suricata con acción `drop`, bloqueando de manera instantánea el tráfico que contenga firmas de inyección SQL o barridos de vulnerabilidades antes de que lleguen a la aplicación web:

**Listing 8:** Reglas de Prevencion Activa en homelab.rules

```
# Bloqueo inmediato de Inyeccion SQL (UNION SELECT)
drop tcp any any -> $HOME_NET $HTTP_PORTS (msg:"[BANK-IPS-DROP]
    Intento SQLi UNION SELECT"; flow:to_server,established; content
    :"UNION"; nocase; content:"SELECT"; nocase; classtype:web-
    application-attack; sid:1000001; rev:1;)

# Bloqueo inmediato de Path Traversal (/etc/passwd)
drop tcp any any -> $HOME_NET $HTTP_PORTS (msg:"[BANK-IPS-DROP]
    Path Traversal /etc/passwd"; flow:to_server,established;
    content:"etc/passwd"; nocase; classtype:web-application-attack;
     sid:1000003; rev:1;)
```

## 4.3 Matriz Comparativa: Estado Inicial vs Estado Mitigado

La **TABLA 5** resume el impacto de las soluciones técnicas implementadas, evidenciando la reducción drástica de la superficie de ataque y el riesgo global del sistema objetivo.

**TABLA 5:** Comparativa Técnica: Estado Inicial (Vulnerable) vs Estado Mitigado

| Aspecto de Seguridad | Estado Inicial (Vulnerable) | Estado Mitigado (Seguro) |
|---|---|---|
| **Base de Datos (5432)** | Expuesta a `0.0.0.0` en toda la LAN. | Confinada a red interna Docker; solo accesible por IPs administradoras. |
| **Cifrado en Tránsito** | Tráfico HTTP plano en puertos 80, 8080, 8082, 3000, 5636. | Redirección obligatoria a HTTPS/TLS 1.3 con suites criptográficas seguras. |
| **Cabeceras HTTP** | Ausencia de protecciones anti-Clickjacking, CSP y HSTS. | Cabeceras OWASP estrictas activas; divulgación de versión desactivada. |
| **Escáneres Maliciosos** | Respuesta normal a herramientas automatizadas (Nikto, SQLMap). | Bloqueo directo por User-Agent (HTTP 403) y neutralización por IPS. |
| **Resiliencia DoS** | Susceptible a hilos bloqueados por conexiones lentas (Slowloris). | Timeouts estrictos (5s) y limitación de tasa (`limit_req` / `limit_conn`). |
| **Inyecciones Web** | La petición llegaba directamente al backend de la aplicación. | Descarte inmediato de paquetes (`drop`) mediante Suricata IPS / NFQUEUE. |

**FUENTE:** Elaboración propia.

# 5. Conclusiones del Ejercicio de Auditoría

El desarrollo integral de la auditoría de seguridad y escaneo de vulnerabilidades sobre la infraestructura del servidor corporativo ha permitido consolidar conclusiones técnicas y estratégicas de alto valor:

1. **Efectividad del Escaneo Multicapa:** La combinación de herramientas complementarias (Nmap para la capa de transporte, OpenVAS para la identificación de fallos de configuración de red, Nikto para la capa web y Trivy para los contenedores) permitió mapear con precisión quirúrgica la superficie de ataque del sistema objetivo, demostrando que ningún escáner individual es suficiente para obtener una visión completa del estado de seguridad.
2. **Riesgo Crítico de la Configuración por Omisión:** Los principales hallazgos de severidad alta detectados (como la exposición pública del puerto PostgreSQL en `0.0.0.0:5432` o la transmisión en texto claro en servicios web internos) no se debieron a vulnerabilidades de día cero (*0-days*) en el código fuente, sino a fallos de configuración operativa y omisión de directivas de aislamiento en los manifiestos de despliegue.
3. **El Rol Transformador de la Prevención Activa (IPS):** La integración de Suricata configurado en modo IPS con `NFQUEUE` y reglas directas con acción `drop` evidenció que es posible neutralizar de forma automática ataques dirigidos (inyecciones SQL y Path Traversal) en el instante de su transmisión, cerrando la brecha temporal entre la detección del incidente y la respuesta manual de los analistas de seguridad.
4. **Validez de la Defensa en Profundidad:** Las medidas de mitigación implementadas demuestran que la seguridad no reside en un único componente defensivo. El blindaje real se alcanza cuando el firewall de kernel (`nftables`), el proxy inverso endurecido (`nginx`), el aislamiento de contenedores (Docker sin privilegios de superusuario) y el sistema de prevención de intrusos operan de manera sincronizada y redundante.

# 5. Recomendaciones para la Operación Continua

Con el fin de preservar y mejorar la postura de ciberseguridad del servidor en el tiempo, se recomienda a la organización:

- **Escaneos Automatizados en Ciclos de Despliegue (DevSecOps):** Incorporar el escaneo estático de imágenes con Trivy en el flujo de integración continua, impidiendo la puesta en producción de contenedores que contengan vulnerabilidades con puntuación CVSS mayor o igual a 7.0.
- **Campañas Periódicas con OpenVAS:** Programar tareas de escaneo automatizadas con Greenbone Community Edition con una frecuencia mensual o ante cualquier modificación estructural en la topología de la red.
- **Monitoreo Centralizado de Alertas en EveBox:** Establecer turnos de revisión de los eventos recolectados por EveBox y configurar notificaciones automáticas ante disparos de firmas de severidad 1 (alta criticidad).
- **Gestión de Parches y Actualizaciones:** Mantener una política formal de actualización de paquetes del sistema operativo base (Debian/Linux) y de las imágenes oficiales de Docker, aplicando parches de seguridad en una ventana no superior a 72 horas tras su publicación.

# Referencias

Aqua Security. (2024). Trivy: Comprehensive vulnerability scanner for containers and systems [Manual de software informático]. Descargado de https://aquasecurity.github.io/trivy/

Center for Internet Security (CIS). (2023a). *CIS debian linux 12 benchmark v1.0.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/debian_linux

Center for Internet Security (CIS). (2023b). *CIS docker community edition benchmark v1.6.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/docker

Forum of Incident Response and Security Teams (FIRST). (2019). Common vulnerability scoring system v3.1: Specification document [Manual de software informático]. Descargado de https://www.first.org/cvss/v3.1/specification-document

Greenbone AG. (2024). Greenbone community edition architecture and documentation – release 24.10 [Manual de software informático]. Osnabrück, Germany. Descargado de https://greenbone.github.io/docs/latest/

Handley, M., y Rescorla, E. (2006). *Internet denial-of-service considerations* (RFC n.º 4732). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc4732 doi: 10.17487/RFC4732

Lyon, G. F. (2009). *Nmap network scanning: The official nmap project guide to network discovery and vulnerability scanning*. Sunnyvale, CA: Insecure.Com LLC.

Open Information Security Foundation (OISF). (2024). Suricata user guide – release 7.0 [Manual de software informático]. Waltham, MA. Descargado de https://docs.suricata.io/en/latest/

Scarfone, K., y Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS)* (Special Publication n.º SP 800-94). Gaithersburg, MD: National Institute of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-94/final doi: 10.6028/NIST.SP.800-94

Scarfone, K., Souppaya, M., Cody, A., y Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (Special Publication n.º SP 800-115). Gaithersburg, MD: National Institute of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-115/final doi: 10.6028/NIST.SP.800-115

Shirey, R. (2000). *Internet security glossary* (RFC n.º 2828). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc2828 doi: 10.17487/RFC2828

van der Stock, A., Glas, B., Smithline, N., y Gigler, T. (2021). *OWASP top 10: The ten most critical web application security risks* (Inf. Téc.). Open Web Application Security Project (OWASP). Descargado de https://owasp.org/Top10/